

F2: Chat History Disclosure via IDOR

Target: Open WebUI v0.3.16 (local lab) | Date: 2026-09-24 Attacker: test2 (standard user) | Victim: test1 (standard user)

Vector

GET /api/v1/chats/{chat_id} with attacker's Bearer token

Result: 200 OK — LEAKY

Returned to attacker:

- full private transcript ("dont tell anyone this one")
- uploaded file CONTENTS via RAG citation ("document":["this is shitty secret mf"])
- server paths (/app/backend/data/uploads/...)
- vector DB collection name

Contrast (why this is a "partial fix" finding)

- /api/v1/files/{id}/content → 404 existence-hidden (FIXED — F1)
- /api/v1/chats/{id} → 200 full JSON (LEAKY — F2) Same changelog claims both were fixed. One router holds, one hands over.

Control (methodology validation)

Victim's own token → 200 (route works, ID correct) Attacker token with EXPIRED/rotated value → 401 (confirmed token validity matters)

Severity: HIGH (horizontal privilege escalation, full transcript + file disclosure)

Repro

```
curl -s "http://127.0.0.1:3000/api/v1/chats/"  
-H "Authorization: Bearer "
```

Separate low finding

JWT sessions carry no exp claim → tokens never expire.